

AUDSPECT

Breach & Attack Simulation Platform

Adversary Simulation Assessment Report

LOLBin Execution Coverage • Full Three-Tier Orchestration

RISK: CRITICAL

Prepared for	DESKTOP-5TVEBSI
Endpoint	Windows/amd64 (10.0.19045)
Environment	Production
Assessment date	10 June 2026, 10:22 UTC
Report generated	10 June 2026, 10:24 UTC
Run reference	18b7b11f

1. Executive Summary

This report presents the results of an automated breach & attack simulation executed against DESKTOP-5TVEBSI (Windows/amd64 (10.0.19045)) on 10 June 2026. The assessment ran 19 MITRE ATT&CK-aligned techniques to measure how effectively the endpoint's security controls prevent real adversary behaviour.

Of the techniques executed, 6 were prevented or blocked by a security control and 13 executed successfully without being stopped. This yields a prevention effectiveness of 31% and an overall risk classification of Critical (risk score 89/100). Consecutive failures across adjacent kill-chain phases amplified exposure by 1.3x, indicating an attacker could chain multiple steps with limited resistance.

11 critical or high-severity technique(s) were not prevented and require prioritised remediation (see Key Findings). Testing exercised 71% of the ATT&CK enterprise kill chain; broadening scenario coverage in future runs will increase assurance. Prioritised recommendations are provided in section 7.

Overall posture: Critical (risk score 89 / 100, Stable)

19 techniques executed - 6 prevented - 13 succeeded - 11 critical/high finding(s)

2. Assessment Scorecard



3. Methodology & Scope

Framework	MITRE ATT&CK (Enterprise)
Engines	Custom checks
Target endpoint	DESKTOP-5TVEBSI - Windows/amd64 (10.0.19045)
Environment	Production
Techniques executed	19
Tactics exercised	3 of 14 ATT&CK tactics
Window	10 Jun 2026 10:22 UTC

Each technique is scored as PASS when a security control prevented or blocked it, FAIL when it executed without being stopped, or SKIPPED when it could not run. A FAIL is a finding - it means the simulated adversary behaviour succeeded against this endpoint.

4. ATT&CK Tactic Breakdown

Initial Access		0%	0 pass - 1 fail
Execution		50%	2 pass - 2 fail
Defense Evasion		0%	0 pass - 2 fail

5. Key Findings

HIGH

F-01 T1059.001 â€” PowerShell Constrained Language Mode

Lolbin Exposure

- What happened** PowerShell in FullLanguage mode â€” all .NET types, P/Invoke, and LOLBin abuse accessible.
- Remediation** Enforce via WDAC policy (most tamper-resistant) or set __PSLockdownPolicy=4. Verify with: \$ExecutionContext.SessionState.LanguageMode

CRITICAL

F-02 T1218.005 â€” mshta.exe Execution Control

Execution

- What happened** mshta.exe not explicitly blocked â€” APT36 HTA dropper execution via spear-phish attachment is possible.
- Remediation** Block mshta.exe via AppLocker Publisher rule or WDAC deny policy. Enable ASR rule: Block Office child processes.

HIGH

F-03 T1059.005 â€” WScript/CScript Execution Control

Execution

- What happened** WScript/CScript not restricted â€” VBScript payloads from APT36 documents can execute freely.
- Remediation** Disable VBScript in Internet Zone (Zone 3, setting 1400=3). Block wscript.exe/cscript.exe via AppLocker.

CRITICAL

F-04 T1566.001 â€” ASR Rule â€” Block Office Child Process Spawning

Prevention Posture

- What happened** ASR rule D4F940AB not configured â€” Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
- Remediation** Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).

HIGH

F-05 T1059.001 â€” PowerShell Script Block Logging

Defense Evasion

- What happened** Script Block Logging not configured â€” PowerShell attack activity not logged to Event ID 4104.
- Remediation** Enable via GPO: Computer Config â†’ PS â†’ Script Block Logging â†’ Enabled.

HIGH

F-06 T1059 â€” Process Command-Line Auditing (EID 4688)

Logging Detection

- What happened** Command-line auditing NOT enabled â€” EID 4688 logs process create without arguments. LOLBin detection is fundamentally blind.
- Remediation** Enable via GPO: Computer Config â†’ Audit Policy â†’ Process Creation â†’ Include command line in process creation events.

CRITICAL

F-07 T1566.001 â€” Office VBA Macro Execution Policy

Initial Access

- What happened** No Office macro restriction policy found â€” VBA payloads may execute on document open.
- Remediation** Block macros from internet via GPO: User Config â†’ Administrative Templates â†’ Microsoft Office â†’ Security Settings â†’ VBA Macro Notification Settings = 4.

HIGH

F-08 T1559.001 â€” ASR Rule â€” Block Win32 API Calls from Office Macros

Prevention Posture

- What happened** ASR rule 3B576869 not configured â€” Office macros can invoke Win32 APIs and COM objects (APT36 GetObject/CreateObject vector open).
- Remediation** Enable ASR rule 3B576869-A4EC-4529-8536-B80A7769E899 via GPO (Block Win32 API calls from Office macros).

HIGH

F-09 T1059 â€” WDAC (Windows Defender Application Control) Base Policy

Lolbin Integrity

- What happened** No WDAC policy detected â€” LOLBin execution unrestricted by code integrity. Microsoft LOLBin blocklist not applied.
- Remediation** Deploy WDAC base policy + Microsoft recommended LOLBin blocklist (supplemental). Use Audit mode first, then Enforcement.

CRITICAL	F-10 T1566.001 ASR Rule Block Office Child Process Spawning	
	Prevention Posture	
	What happened	ASR rule D4F940AB not configured Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
HIGH	Remediation	Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).
	F-11 T1059.007 ASR Rule Block JS/VBScript from Launching Executables	
	Parent Child Protection	
HIGH	What happened	ASR rule D3E037E1 not configured JS/VBScript can launch executables via WScript.Shell (browserâ€™s LOLBin chain open).
	Remediation	Enable ASR rule D3E037E1-3EB8-44C8-A917-57927947596D (Block JS or VBScript from launching downloaded executable content).

6. Detailed Technique Results

PASS	T1059 Application Control (AppLocker/WDAC)	
	Execution - High	
	Details	AppLocker effective policy found.
FAIL	Threat impact	Without application control, attackers run arbitrary executables and scripts.
	Remediation	Configure AppLocker or WDAC to allow-list approved applications only.
	T1059.001 PowerShell Constrained Language Mode	
FAIL	Lolbin Exposure - High	
	Details	PowerShell in FullLanguage mode all .NET types, P/Invoke, and LOLBin abuse accessible.
	Threat impact	Without Constrained Language Mode, PowerShell allows type creation, P/Invoke, and Add-Type the foundation of LOLBin execution and AMSI bypass.
FAIL	Remediation	Enforce via WDAC policy (most tamper-resistant) or set __PSLockdownPolicy=4. Verify with: \$ExecutionContext.SessionState.LanguageMode
	T1218.005 mshta.exe Execution Control	
	Execution - Critical	
FAIL	Details	mshta.exe not explicitly blocked APT36 HTA dropper execution via spear-phish attachment is possible.
	Threat impact	APT36 uses mshta.exe to execute HTA payloads a signed Windows binary that bypasses most script restrictions.
	Remediation	Block mshta.exe via AppLocker Publisher rule or WDAC deny policy. Enable ASR rule: Block Office child processes.
FAIL	T1059.005 WScript/CScript Execution Control	
	Execution - High	
	Details	WScript/CScript not restricted VBScript payloads from APT36 documents can execute freely.
FAIL	Threat impact	APT36 uses VBScript via wscript.exe for second-stage payload execution after the HTA dropper.
	Remediation	Disable VBScript in Internet Zone (Zone 3, setting 1400=3). Block wscript.exe/cscript.exe via AppLocker.
	T1566.001 ASR Rule Block Office Child Process Spawning	
FAIL	Prevention Posture - Critical	
	Details	ASR rule D4F940AB not configured Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
	Threat impact	APT36 weaponised documents spawn cmd.exe/powershell.exe as Office child processes to execute CrimsonRAT. This ASR rule directly blocks that chain.
FAIL	Remediation	Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).
	T1562.001 Sysmon Endpoint Monitoring	
	Defense Evasion - Medium	
FAIL	Details	Sysmon not installed limited endpoint visibility for threat hunting.
	Threat impact	Without Sysmon, process injection, network connections, and file drops are not logged.
	Remediation	Deploy Sysmon with SwiftOnSecurity or Olaf config on all endpoints.

FAIL	T1059.001 PowerShell Script Block Logging		Script Block Logging not configured PowerShell attack activity not logged to Event ID 4104.
	Threat impact		Without Script Block Logging, malicious PowerShell is executed and exfiltrated unlogged.
	Remediation		Enable via GPO: Computer Config PS Script Block Logging Enabled.
PASS	T1562.001 AMSI Enforcement (Anti-Malware Scan Interface)		AMSI enabled with 1 registered provider(s) PowerShell, VBScript, and Office macro content scanned at runtime.
	Threat impact		APT36 PowerShell stagers and CrimsonRAT loaders use AMSI bypass techniques to evade real-time script scanning before initial execution.
	Remediation		Ensure AmsiEnable%0 in HKCU\SOFTWARE\Microsoft\Windows Script\Settings. Deploy EDR with AMSI provider integration.
FAIL	T1059.001 PowerShell Transcription Logging		PowerShell Transcription not configured obfuscated LOLBin PS commands leave no reconstructible audit trail.
	Threat impact		Transcription records all PS input/output essential for forensic reconstruction of obfuscated LOLBin chains. Without it, obfuscated PS leaves no audit trail.
	Remediation		Enable via GPO: Computer Config PowerShell Turn on PowerShell Transcription. Set a secure network output directory.
FAIL	T1059 Process Command-Line Auditing (EID 4688)		Command-line auditing NOT enabled EID 4688 logs process create without arguments. LOLBin detection is fundamentally blind.
	Threat impact		Without command-line capture, LOLBin arguments (certutil -decode, regsvr32 /i:*, mshta vbscript:) are invisible in EID 4688 LOLBin detection is fundamentally blind.
	Remediation		Enable via GPO: Computer Config Audit Policy Process Creation Include command line in process creation events.
PASS	T1047 WMI Activity Logging (EID 5857-5860)		WMI-Activity/Operational log enabled (1MB) WMI process creation (EID 5857-5860) captured.
	Threat impact		WMI process creation is invisible without WMI event logging used for LOLBin parent-process spoofing and fileless lateral movement with no disk artefacts.
	Remediation		Enable via: wevtutil sl Microsoft-Windows-WMI-Activity/Operational /e:true /ms:536870912. Set retention 512MB.
PASS	T1021.006 WinRM Remote Execution Surface		WinRM service is not running remote PS execution surface minimised.
	Threat impact		Running WinRM allows lateral movement via PowerShell remoting from any network attacker.
	Remediation		Disable if not needed: Stop-Service WinRM; Set-Service WinRM -StartupType Disabled.
PASS	T1569.002 PsExec Presence / Lateral-Movement Surface		PsExec not detected in standard paths lateral movement LOLBin surface reduced.
	Threat impact		PsExec is the most common LOLBin for lateral movement and ransomware deployment its presence on non-admin workstations is a persistent risk.
	Remediation		Remove PsExec from standard workstations. Block via AppLocker publisher rule. Require dedicated jump-host for legitimate remote execution.
FAIL	T1566.001 Office VBA Macro Execution Policy		No Office macro restriction policy found VBA payloads may execute on document open.
	Threat impact		APT36 delivers CrimsonRAT/ObliqueRAT via weaponised Office documents VBA macro execution is the initial foothold.

FAIL	T1559.001 ASR Rule Block Win32 API Calls from Office Macros Prevention Posture - High
Details	ASR rule 3B576869 not configured - Office macros can invoke Win32 APIs and COM objects (APT36 GetObject/CreateObject vector open).
Threat impact	APT36 uses Office COM automation (GetObject/CreateObject) to execute payloads without spawning a visible child process, evading process-chain detections.
Remediation	Enable ASR rule 3B576869-A4EC-4529-8536-B80A7769E899 via GPO (Block Win32 API calls from Office macros).

FAIL	T1059 WDAC (Windows Defender Application Control) Base Policy Lolbin Integrity - High
Details	No WDAC policy detected - LOLBin execution unrestricted by code integrity. Microsoft LOLBin blocklist not applied.
Threat impact	WDAC is the strongest LOLBin prevention - code integrity policy blocks unsigned/untrusted binaries and restricts LOLBin abuse. Without it, the entire LOLBin surface is open.
Remediation	Deploy WDAC base policy + Microsoft recommended LOLBin blocklist (supplemental). Use Audit mode first, then Enforcement.

PASS	T1036.003 Key LOLBin Authenticode Signature Integrity Lolbin Integrity - High
Details	Key LOLBins (mshta/regsrvr32/certutil/rundll32/wscript/cscript/msbuild) all have valid Authenticode signatures - no tampering detected.
Threat impact	Attackers replace key LOLBins with trojanised copies - verifying Authenticode signatures confirms mshta/regsrvr32/certutil/rundll32 have not been tampered with.
Remediation	Monitor key LOLBin signatures and file hashes via FIM. Alert on any signature invalidation for system32 LOLBins.

FAIL	T1566.001 ASR Rule Block Office Child Process Spawning Prevention Posture - Critical
Details	ASR rule D4F940AB not configured - Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
Threat impact	APT36 weaponised documents spawn cmd.exe/powershell.exe as Office child processes to execute CrimsonRAT. This ASR rule directly blocks that chain.
Remediation	Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).

FAIL	T1059.007 ASR Rule Block JS/VBScript from Launching Executables Parent Child Protection - High
Details	ASR rule D3E037E1 not configured - JS/VBScript can launch executables via WScript.Shell (browser+LOLBin chain open).
Threat impact	Browser-driven LOLBin chains use JS/VBScript to launch executables via WScript.Shell - this ASR rule blocks that parent-child vector.
Remediation	Enable ASR rule D3E037E1-3EB8-44C8-A917-57927947596D (Block JS or VBScript from launching downloaded executable content).

7. Prioritised Recommendations

- 1 Overall prevention score is critically low. Prioritise endpoint hardening and EDR deployment across all assets.
- 2 Exposure score exceeds 60. Deploy a 24/7 SOC with SIEM correlation rules aligned to detected failure patterns.

8. Appendix - Metric Definitions

PASS	A security control prevented or blocked the simulated technique. More passes is better.
FAIL	The technique executed successfully without being stopped - a finding requiring attention.

SKIPPED	The technique could not run (e.g. prerequisite missing) and was excluded from scoring.
Prevention	Severity-weighted percentage of techniques that were prevented. Higher is better.
Exposure	Tactic-weighted failure rate, amplified by consecutive kill-chain failures. Lower is better.
Tactic Coverage	Breadth of testing: how many of the 14 MITRE ATT&CK Enterprise tactics this run exercised.
Defense Rate	Share of tested tactics in which every technique was blocked (zero failures).
Kill-chain amplifier	Multiplier (1.0–2.5) reflecting consecutive unprevented kill-chain phases.
Risk classification	Overall posture band derived from the amplified exposure score.